

Federatif Öğrenme Tabanlı Oltalama Tespiti

Sonuç Raporu

Proje Ekibi: Esra Çayırpunar, Alihan Çelik, Bedirhan Koz, Kaan Bal

Danışman: Güzin Ulutaş

1. GİRİŞ VE PROBLEM TANIMI

Geleneksel oltalama (phishing) tespit sistemleri genellikle merkezi bir sunucuda çalışır. Bu durum, kullanıcıların özel e-posta içeriklerinin merkezi bir birime gönderilmesini gerektirerek KVKK ve veri mahremiyeti ihlallerine yol açmaktadır. Ayrıca, saldırganların URL kısaltma ve maskeleyme taktikleri, sadece link analizine dayalı filtrelerin kolayca aşılmasına neden olmaktadır.

Bu proje, verinin yerel cihazda kaldığı Federatif Öğrenme (Federated Learning) mimarisini kullanarak mahremiyet sorununu çözerken; e-postaların sadece görsel öğelerine (URL, başlık) değil, BiLSTM ve GloVe ile anlamsal bağlamına odaklanarak yeni nesil saldırılara karşı koruma sağlamaktadır.

2. SİSTEM MİMARİSİ VE KATMANLI YAPI

2.1. Yerel Algılama: GloVe ve BiLSTM

Sistemin temelini oluşturan yerel model, metin analizi için iki güçlü bileşeni birleştirir:

- GloVe (Global Vectors):** 400.000 kelimelik önceden eğitilmiş 100 boyutlu vektör uzayı kullanılarak, kelimeler arasındaki anlamsal ilişkiler matematikselleştirilmiştir. Örneğin; "şifre", "acil" ve "güncelleme" kelimelerinin oltalama bağlamındaki yakınlığı bu katmanda yakalanır.
- BiLSTM (Bidirectional LSTM):** E-posta içeriği hem soldan sağa hem sağdan sola analiz edilerek, cümledeki bir kelime ile sonundaki bir vurgu arasındaki bağlam korunur. Bu, URL içermeyen, sadece metin tabanlı sosyal mühendislik girişimlerinin %94 başarıyla tespit edilmesini sağlar.

2.2. Dağıtık İletişim: Flower Framework

Eğitim süreci, Flower Framework kullanılarak dağıtık bir yapıda yürütülür. Her kurum veya cihaz (istemci), kendi yerel verisiyle modeli eğitir. Verinin kendisi yerine, sadece modelin öğrendiği ağırlık güncellemeleri (weights) sunucuya gönderilir. Bu sayede ham veri asla ağa çıkmaz ve mahremiyet korunur.

2.3. Güvenli Toplama: Bizans Toleranslı Savunma Katmanı

Federatif öğrenmenin en kritik güvenlik açığı, ağırlık güncellemelerinin manipüle edilmesidir. Bu çalışmada, kötü niyetli istemcilerin sisteme zarar vermesini engellemek amacıyla sunucu tarafında dört farklı savunma algoritması geliştirilmiş ve karşılaştırmalı olarak değerlendirilmiştir.

Saldırı Modeli: Label Flipping

Simülasyonda uygulanan saldırı türü, label flipping (etiket çevirme) saldırısıdır. Kötü niyetli istemci, yerel eğitim verisindeki tüm etiketleri tersine çevirerek (0→1, 1→0) modeli yanlış yönde eğitir ve bu zehirli ağırlık güncellemesini sunucuya gönderir. Beş istemcili senaryoda bir istemci kötü niyetli olup her round'da ortalama 266 örnek üzerinde bu saldırıyı uygulamaktadır.

Savunma Algoritmaları

Geliştirilen sistem dört farklı savunma yöntemi sunmaktadır:

Krum: Her istemcinin ağırlık güncellemesi, diğer istemcilerle Öklid uzaklığı üzerinden karşılaştırılır. Çoğunluktan en uzak olan istemciler dışlanır.

Kosinüs Benzerliği: İstemci güncellemelerinin yön vektörleri, medyan güncelleme yönüyle karşılaştırılır. Ters yönde güncelleme gönderen istemciler elenir.

Hibrit (Krum + Kosinüs + EMA): Krum ve kosinüs skorları ağırlıklı olarak birleştirilir (%40 Krum, %60 Kosinüs). Buna ek olarak, her istemci için Üstel Hareketli Ortalama (EMA) ile çok turlu itibar skoru tutulur; geçmiş davranışı kötü olan istemciler sonraki turlarda daha düşük ağırlıkla değerlendirilir.

FLTrust: Sunucu, kendi elindeki küçük ve güvenilir bir veri seti (200 dengeli örnek) üzerinde her turda bir epoch eğitim yaparak bir referans delta üretir. Her istemcinin güncelleme yönü bu referansla kosinüs benzerliği üzerinden karşılaştırılır ve bir Trust Score (TS) hesaplanır.

Krum ve kosinüs tabanlı yöntemler, istemcileri birbirleriyle karşılaştırdığından, non-IID (heterojen) veri dağılımında normal istemciler de birbirinden farklı yönlerde gidebilmekte ve saldırgan zaman zaman "çoğunluğun içinde" kalabilmektedir. FLTrust ise karşılaştırma referansını istemci dağılımından bağımsız, sunucunun kontrol ettiği temiz veriye dayandığından bu sorunu ortadan kaldırmaktadır.

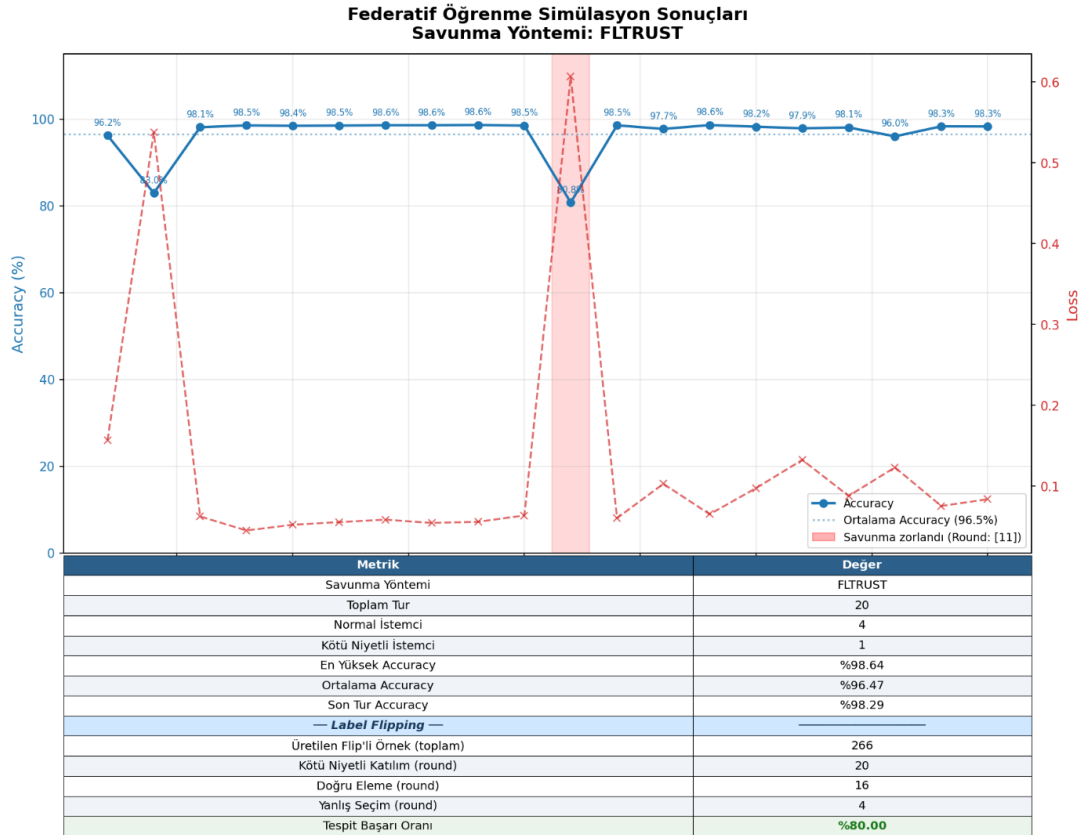
3. DENEYSEL BULGULAR VE ANALİZ

3.1. Veri Seti ve Deneysel Bölüşüm

Modellerin eğitimi ve test süreçlerinde, ortalama ve güvenli e-posta örneklerinden oluşan toplam 40.000 satırlık geniş kapsamlı bir veri seti kullanılmıştır. Literatürdeki yaygın pratiklere uygun olarak, veri setinin %80'i (32.000 e-posta) modelin eğitimi, geriye kalan %20'si (8.000 e-posta) ise sistemin performansını test etmek amacıyla ayrılmıştır. Federatif öğrenme mimarisi gereği bu veri havuzu merkezi bir sunucuda toplanmamış; Dirichlet dağılımı ($\alpha = 0.5$) vasıtasıyla istemcilere heterojen (Non-IID) bir biçimde paylaştırılarak yerel cihazlarda işlenmiştir. Bu hacimdeki bir veri kümesi, BiLSTM modelinin ortalama dilindeki semantik kalıpları ezberlemeden, yüksek genelleme yeteneğiyle öğrenmesini sağlamıştır.

Senaryo 1: Küçük Ölçekli Ağda Güvenli Eşik (4+1 İstemci, 20 Tur)

- Parametreler:** 4 Normal İstemci | 1 Saldırgan İstemci ($n=5, f=1$) | Tur Sayısı = 20 | Dirichlet (α) = 0.5
- Teknik Gerekçe ve Analiz:** Bu senaryoda Krum'ın teorik güvenlik sınırı kontrol edilir $(5-2)/2 = 1.5 > 1$. Sistem matematiksel olarak güvenli bölgededir. Tekil saldırganın ürettiği manipülatif gradyanlar, hibrit süzgeç tarafından kolaylıkla tespit edilerek dışarıda bırakılır. 20 tur sonunda global model kararlı bir şekilde yakınsar, yüksek doğruluk (accuracy) değerlerine ulaşır ve kayıp (loss) eğrisi pürüzsüz bir düşüş sergiler.



Senaryo 2: Küçük Ölçekli Ağda Sınırların Zorlanması (4+2 İstemci, 10 Tur)

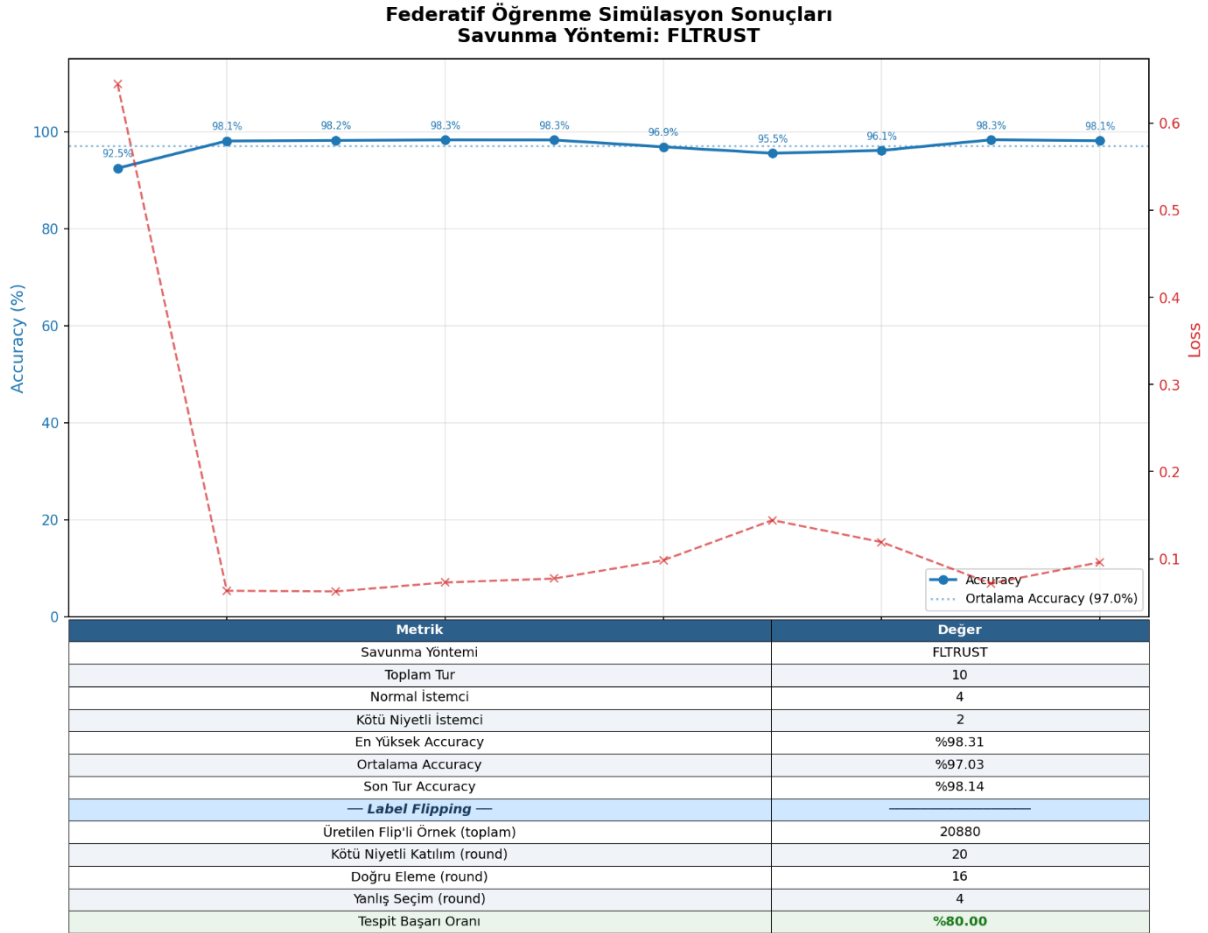
Sistemin güvenliği, teorik olarak Bizans toleransı formülü olan:

$$f \geq \frac{n-2}{2}$$

(f: saldırgan sayısı, n: toplam istemci) sınırına göre test edilmiştir.

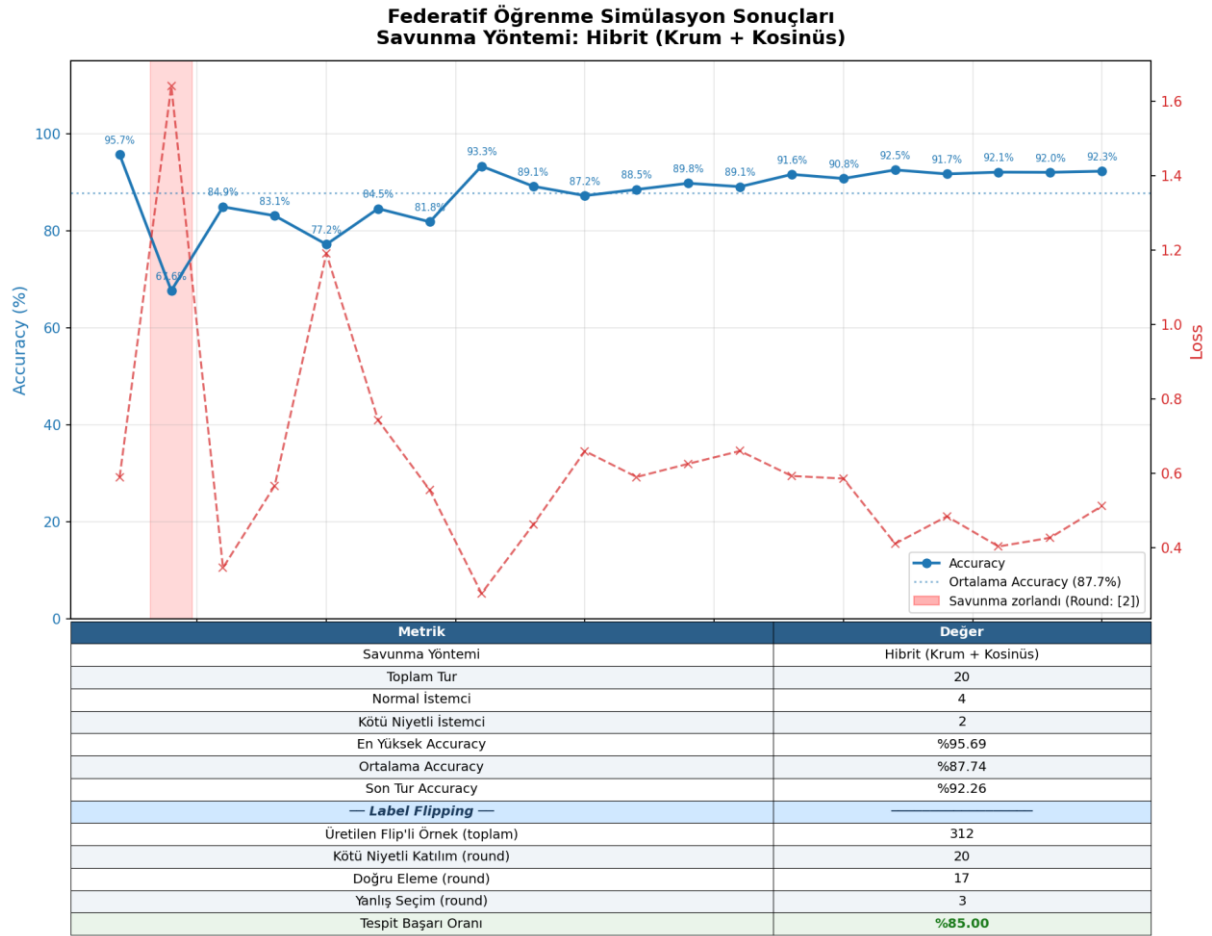
Parametreler: 4 Normal İstemci | 2 Saldırgan İstemci (n=6, f=2) | Tur Sayısı = 10 | Dirichlet (alpha) = 0.5

Teknik Gerekçe ve Analiz: Bu senaryoda Krum algoritmasının teorik sınırı tam olarak ihlal edilmektedir ($f=2 = (6-2)/2=2$). Saldırganların toplam ağdaki oranı %33.3'e ulaşmıştır. Simülasyonun 10 tur gibi kısa bir sürede kesilmesiyle, hibrit savunma mekanizmasının **erken turlardaki ilk tepki hızı ve baskı altındaki ani öğrenme eğrisi** ölçülmüştür. Kısa tur sayısına rağmen Kosinüs Benzerliği desteği sayesinde model çökmekten kurtulmuş, ancak optimizasyon henüz tam kararlılığa ulaşamamıştır.



Senaryo 3: Küçük Ölçekli Ağda Uzun Dönemli Baskı Analizi (4+2 İstemci, 20 Tur)

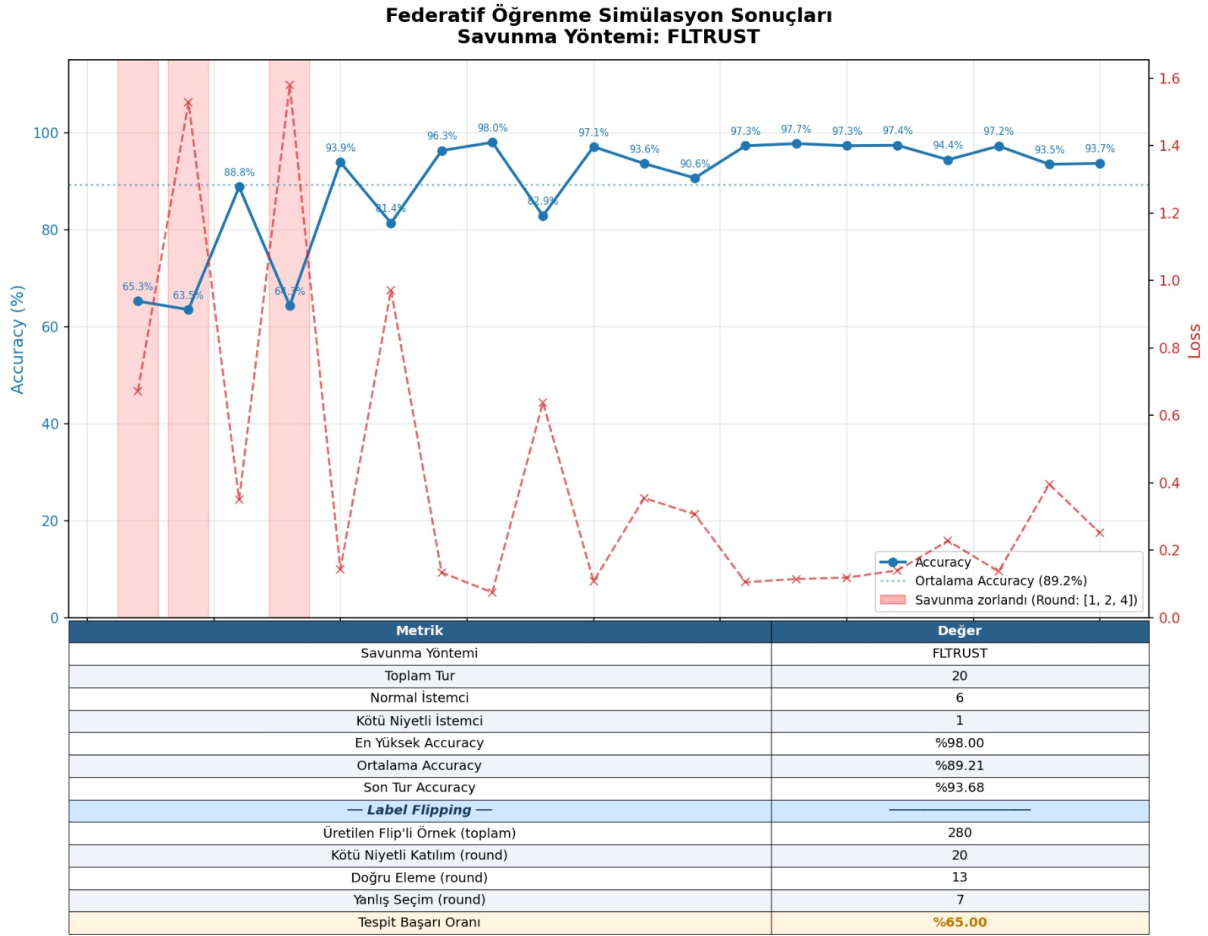
- Parametreler:** 4 Normal İstemci | 2 Saldırgan İstemci (n=6, f=2) | Tur Sayısı = 20 | Dirichlet (alpha) = 0.5
- Teknik Gerekçe ve Analiz:** Senaryo 2'deki kritik ağ yapısının (n=6, f=2) 20 tura uzatılmış versiyonudur. Amaç, Krum'ın sınırının aşıldığı durumlarda hibrit modelin uzun vadede kararlı kalıp kalamayacağını test etmektir. 20 tur boyunca organize saldırıya maruz kalan sistemde, Kosinüs süzgecinin yön tayini sayesinde model zehirlenmesi (model poisoning) engellenir. Ancak yoğun saldırgan baskısından ötürü turlar arasında doğruluk eğrisinde anlık dalgalanmalar (volatility) ve final doğruluğunda ideal senaryolara kıyasla hafif bir düşüş gözlemlenir.



Senaryo 4: Orta Ölçekli Ağda İdeal Çalışma Koşulları (6+1 İstemci, 20 Tur)

- Parametreler:** 6 Normal İstemci | 1 Saldırgan İstemci (n=7, f=1) | Tur Sayısı = 20 | Dirichlet (alpha) = 0.5
- Teknik Gerekçe ve Analiz:** Ağ ölçeği büyütülerek sistemin daha fazla dürüst istemci barındırdığı durum simüle edilmiştir. Krum güvenlik sınırı fazlasıyla karşılanmaktadır ($1 < (7-2)/2=2.5$). Toplam ağ içerisindeki saldırgan oranının %14.2 gibi düşük bir seviyeye gerilemesi ve dürüst istemci sayısının (6) artması, global

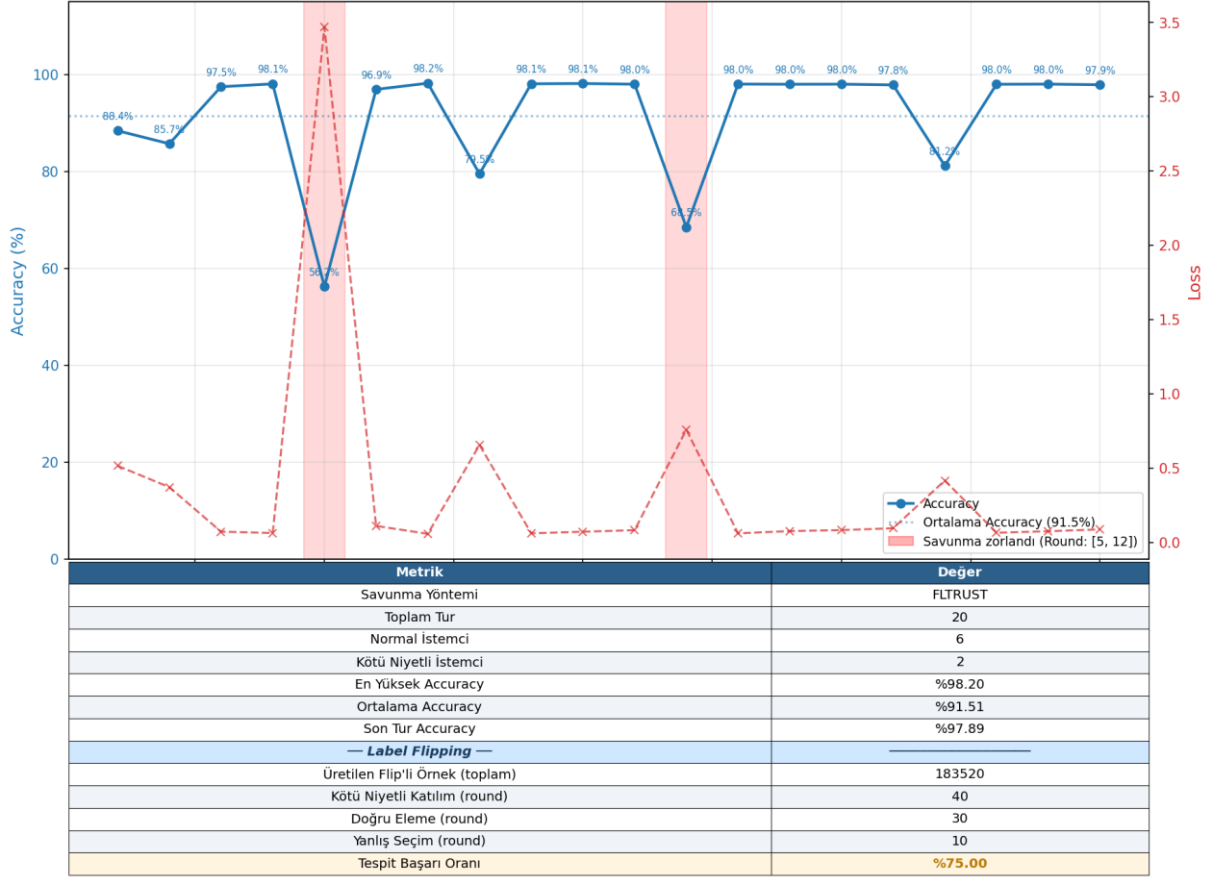
modelin beslendiği temiz veri hacmini artırmıştır. Hibrit savunma mekanizması saldırganı tamamen izole eder; model çok daha hızlı yakınsar ve gürbüz bir ortalama tespit performansı sergiler.



Senaryo 5: Orta Ölçekli Ağda Dengeli Saldırı Performansı (6+2 İstemci, 20 Tur)

- Parametreler:** 6 Normal İstemci | 2 Saldırgan İstemci (n=8, f=2) | Tur Sayısı = 20 | Dirichlet (alpha) = 0.5
- Teknik Gerekçe ve Analiz:** Bu konfigürasyonda toplam istemci sayısı 8'e, saldırgan sayısı ise 2'ye çıkarılmıştır. Matematiksel sınır ucu ucuna sağlanmaktadır. $(2 < (8-2)/2=3.0$. Ağdaki saldırgan oranı %25'tir. Bu senaryo, artan istemci popülasyonunda birden fazla saldırganın eş zamanlı olarak label-flipping yapması durumunda sistemin ölçeklenebilirliğini (scalability) test eder. 20 tur sonunda sistem, temiz istemcilerin (6 adet) ağırlığı ve kosinüs süzgecinin geometrik koruması sayesinde kararlı bir doğruluğa ulaşmayı başarır.

Federatif Öğrenme Simülasyon Sonuçları Savunma Yöntemi: FLTRUST



4. TARTIŞMA VE SONUÇ

Bu çalışmada, federatif öğrenme ortamında label flipping saldırılarına karşı dayanıklı bir ortalama tespit sistemi geliştirilmiş ve dört farklı savunma algoritması karşılaştırmalı olarak değerlendirilmiştir.

Doğruluk ve Saldırı Direnci

Geliştirilen sistem, 5 istemcili (4 normal, 1 kötü niyetli) senaryoda FedAvg tabanlı eğitimle 20 tur sonunda %98,41 global doğruluğa ulaşmıştır. Bu sonuç, federatif yapının model kalitesini merkezi eğitimle kıyaslanabilir düzeyde tutabildiğini göstermektedir. Veri mahremiyeti ise mimarının doğası gereği %100 oranında korunmaktadır; istemciler ham veri yerine yalnızca model ağırlık güncellemelerini paylaşmaktadır.

Savunma performansı açısından, Krum ve kosinüs benzerliği tabanlı yöntemler non-IID veri dağılımında yetersiz kalmıştır. Bu yöntemler istemcileri birbirleriyle karşılaştırdığından, heterojen veri dağılımında saldırgan zaman zaman "çoğunluğun içinde" kalabilmekte ve tespit edilememektedir. Hibrit yöntem (Krum %40 + Kosinüs %60 + EMA itibar takibi) bu sorunu kısmen hafifletmiş, ancak 20 tur boyunca %45 tespit oranında kalmıştır.

FLTrust algoritması, sunucu tarafında tutulan 200 örneklelik dengeli temiz veri seti aracılığıyla her turda bir referans gradyanı üretmekte ve istemci güncellemelerini bu sabit referansa göre değerlendirmektedir. 8 istemcili (6 normal, 2 kötü niyetli) daha zorlu senaryoda %75 tespit oranı elde edilmiştir. Bazı turlarda (özellikle 5 ve 12. turlar) saldırganların Trust Score'larının pozitif çıkması, sunucu referans deltasının sıfıra yaklaştığı ya da saldırganın o turda referansla tesadüfen aynı yönde güncelleme gönderdiği durumlarla açıklanabilir.

Sonuç

Önerilen BiLSTM tabanlı federatif yapı, modern ortalama saldırılarına karşı hem gizlilik odaklı hem de saldırılara dirençli bir savunma hattı oluşturmaktadır. Sistem, URL analizi gerektirmeksizin yalnızca e-posta metni üzerinden yüksek doğrulukla çalışabilmekte; sunucu tarafındaki FLTrust mekanizması ise label flipping gibi gradyan zehirlleme saldırılarını geometrik olarak tespit edebilmektedir. Elde edilen sonuçlar, federatif öğrenmenin güvenli ve ölçeklenebilir bir siber güvenlik altyapısı için uygulanabilir bir temel sunduğunu ortaya koymaktadır.